

THREAT ACTOR TYPES IN CYBERSECURITY

Contents

Introduction 2

Script Kiddies Threat Model..... 3

Insiders Threat Model..... 4

Opportunistic Attackers Threat Model 5

Competitors Threat Model 6

Organised Cybercriminals Threat Model..... 7

Hactivist Threat Model..... 9

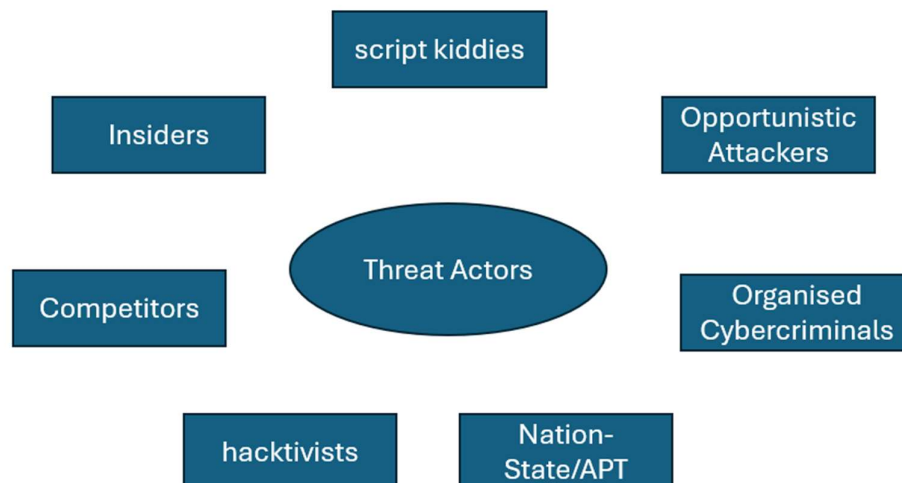
Nation-state/APT Threat Model 11

Introduction

This threat actor documentation is a documentation stating the current threat actors in cybersecurity currently in 2026. This threat actor documentation will cover the definition of each action, their motivation, common attack vectors, targets and protections you can use to defend against these threat actors. This threat actor documentation was created to help users and organisations identify their threat model correctly. There are 7 threat actors that this documentation covers. These threat actors are script kiddies, insiders, opportunistic attackers, competitors, organised cybercriminals, hacktivists and nation-state/APT. For those who aren't technical, APT stands for Advanced Persistent threat. Scammers are integrated with the opportunistic attacker threat actor for those that may be wondering.

It is important that a user or company accurately chooses their threat model based on the data store or activities they currently do. This is important because it allows for accurate and effective security protections against those who are realistically likely to target you. For example, a whistleblower may have a threat model of nation-state/APT. This means that they would implement protections such as air-gapped networks, Tails OS and hardware keys compared to the average user who would have a threat model such as script kiddie and opportunistic attackers. This means that the average user would implement strong passwords, MFA and encrypted recovery codes. You can have multiple threat models depending on the data you store or actives you perform.

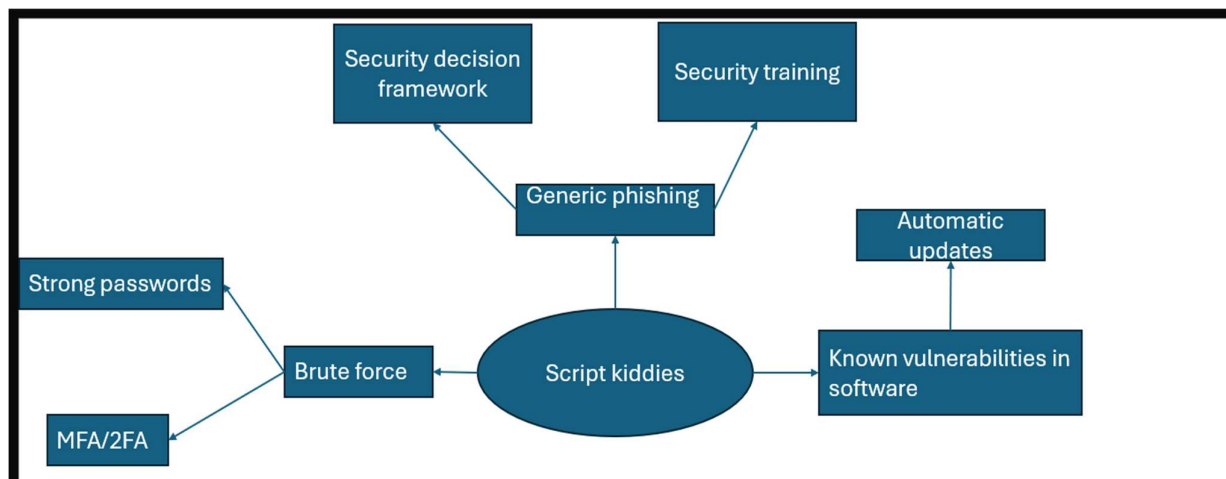
The protections within this threat actor documentation will be mainstream protections against common attack vectors. This means that you will need to do additional research on protections against your specific threat models. Do not blindly trust this threat actor document as it can be wrong. Adapt it to your own security needs.



In the spider diagram above, the actors are stored in the order of the most common and least dangerous starts from the top with script kiddies and the least common and most dangerous at the bottom with Nation-State/APT.

Script Kiddies Threat Model

The most common threat actor is script kiddies. Script kiddies are attackers who use automated tools or pre-existing malware to gain unauthorised access. Script kiddies' motivation comes from the thrill of hacking, sometimes revenge, and rarely money. Script kiddies commonly use brute force, known vulnerabilities in software and phishing to gain unauthorised access. Their targets are usually those who have weaker security or those who are more vulnerable like elderly or people who don't invest into security. There are a few ways to defend yourself from a script kiddie. The first way is to use strong 16-character passwords unique across each account. These passwords should be stored within a password manager with a memorable but strong master password. The second way is through MFA. Options such as authentication apps can stop most script kiddies and hardware keys prevent unauthorised by them nearly completely. I would not suggest using SMS or email-based MFA. The third way to defend yourself is by enabling automatic updates to get the latest patches for software and tools. These updates should be applied across apps, operating systems and firmware. One final way to defend yourself is train yourself against phishing by using a personalised security decision framework, detection systems and OPSEC to prevent spear-phishing attacks. However, phishing cannot be stopped completely for everyone. If you would like more information on protections, then you may look at my security architecture or perform your own research.



In the spider diagram above, we can see the 3 most common attack vectors for script kiddies and the protections for each attack vectors. It is important to note that this diagram doesn't include OPSEC as it is included in the paragraph above and is more effective in other threat models

Insiders Threat Model

Another threat actor is insiders. Insiders are people who already have proximity or access to the system. This can include family members, friends or employees. Insiders usually use pre-existing trust or access to gain access to sensitive data. Insiders are usually motivated by curiosity, money, revenge, coercion and accidental. Coercion is where they are physically, emotionally or digitally threatened by another person. Accidental is when they install something they shouldn't or shoulder surf your password. Insiders use physical observation, unattended devices, abusing legitimate access or social engineering you directly. Insiders can target anyone; however, they usually specifically target companies or friends after arguments or disagreements. There are 4 main ways you can defend yourself from insiders. The first way is to have encrypted backups isolated and not shared with anyone. For individual users, this could be an isolated cloud account not shared to family or friends. For companies, this could be implemented through RBAC with only certain members knowing where backups are located. For both companies and users, backups could be stored across cloud storage, physical drives, encrypted containers on devices or paper storage. The second way is muscle memory for locking your device when leaving it unattended. This means that every time you step away from your device, it will be locked as you will naturally remember to do so. This protects you because an insider cannot access data on your device if its locked and they don't have the passcode. The third way is separating standard and admin accounts. Implementation of this protection will vary across operating systems. For example, Windows uses standard and admin accounts while Linux requires root for certain commands. This protection means that if an insider got access to your device while it was unlocked, they wouldn't be able to install software or access certain data without admin-level permissions. The fourth way is to use app-level passcodes for sensitive accounts. This means an additional authentication process that an insider must bypass to access the data within that app. These passcodes should be alphanumeric or require biometrics to bypass. This protects you because an insider cannot access your sensitive accounts through applications if they were to gain access through shoulder surfacing or while the device was unlocked. While these 4 aren't the only ways, they reduce the attack surface of an insider significantly. If you wish to implement more protections, you may look at my architecture or do your own research on the domain of access control.

Opportunistic Attackers Threat Model

The third most common threat actor is opportunistic attackers. Opportunistic attackers are actors that target vulnerable systems through the usage of automated tools.

Opportunistic attackers usually involve scammers or script kiddie's who wait for specific chances to target a vulnerable system. Opportunistic attackers are motivated by easy money, usually ransomware or cryptominers. This is because compared to insider threats or script kiddies they only attack systems that are vulnerable and offer more reward than risk for the attacker. Opportunistic attackers often use methods such as automated scanning for vulnerabilities within devices and software, known vulnerabilities, weak RDP passwords and ransomware. These actors don't target anyone specifically, instead they target systems and those detected by their automated scans. There are 4 main ways you can defend against this threat actor. The first way is automatic updates for software and firmware. This is because automatic updates allow your devices or applications to receive the latest security updates. This protects against opportunistic attackers as they heavily rely on known and unpatched vulnerabilities within systems. The second way is to use anti-virus software with ransomware protection. For example, Windows Defender uses controlled folder access to protect your data against ransomware. However, be warned that sometimes this software can have false positives as nothing is ever perfect. This protects against opportunistic attacks because they rely heavily on ransomware to collect payments from those who don't have backups or feel forced to pay to gain back their data. The third way is to use a mixture of email separation + strong passwords + MFA. This means that you wouldn't use the same email for all your accounts. This is because having one master email creates a single point of failure within your security. This protects against opportunistic attackers because it requires them to compromise multiple accounts and bypass multiple security steps. Therefore, the risk and cost would be too high forcing them to move onto to an easier target. The fourth and final main way is emergency funds in isolated bank account. While this may seem like its not a technical control, it acts as a last resort recovery option in case. This is because this threat actor is more likely to target your bank accounts as their main motivation is money. By having emergency funds, you can recover and the blast radius of bank account compromise is lower. These 4 ways reduce the attack surface significantly, provide redundancy and raise the cost for an attacker to breach your system. If you wish to implement more protections, you may look at my architecture or risk management framework. You may also perform research on vulnerability management, further protections in the domains of account security, Wi-Fi security and OPSEC.

Competitors Threat Model

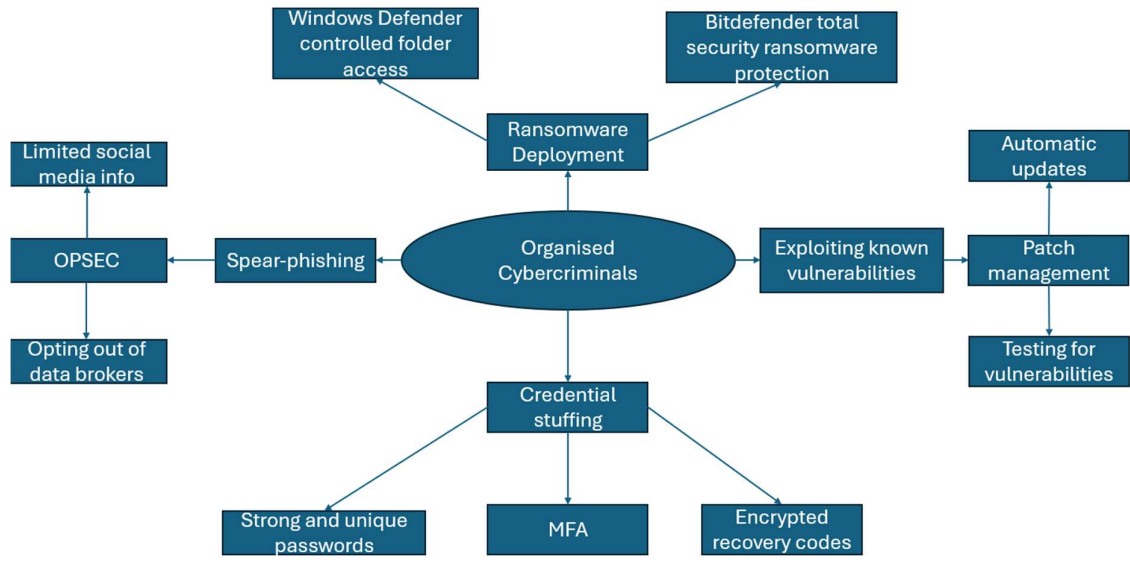
The fourth most common threat actor are competitors. Competitors are threat actors who work for another business targeting other businesses usually within the same industry. Competitors are usually motivated by two factors. The first factor is economic gain by seizing or stealing financial assets from the target company. The second factor is sabotaging the business operations of the target company. This can lead to consequences such as losing customer trust, halting of business operations and reputation damage . Competitors use attack vectors such as social engineering, supply-chain attacks, insider threats and MITM. Social engineering is used by competitors on the target's employees to gain credentials. These credentials can then later be used for gaining unauthorised access into the target's assets or customer data. Supply-chain attacks are attacks that compromise third-party systems to compromise the target. Competitors may use supply-chain attacks by compromising clients or third-party software that the target company works with or uses. Insider threats are used by competitors to abuse legitimate access as they usually work with a corrupt or forced employee to gain unauthorised access. This can lead to the competitors gaining access to customer data and business assets. MITM otherwise known as man in the middle attacks are used to intercept data while in transit. Competitors may use this to intercept data from the company like customer data, business assets or even credentials. Competitors specifically target businesses with the same overlapping customer base and valuable intellectual property. Competitors do not usually target individual people. There are 3 main protections that a company can use to protect their assets and customer data. The first protection is RBAC. RBAC stands for role-based access control. For example, a company may implement limited access for third parties and employees within the company itself. This protects against supply-chain attacks as an attacker cannot use compromise third-party systems to completely compromise company systems. The second protection is IDS/IPS systems. IDS stands for Intrusion detection system while IPS stands for Intrusion prevention system. These systems are used to detect malicious activity on a network. For example, a company may implement IDS to alert them of any malicious or suspicious activity. This protects the company as it allows them to detect potential insider threats and sometimes MITM attacks. The third protection is security awareness training. This means training employee regularly or quarterly to recognise the signs of phishing. For example, a company may also train employees on basic OPSEC to control the information competitors can use for a spear-phishing attack. This heavily reduces the success of phishing. More advanced protections can include custom firewall rules with whitelisting for specific IP's or apps and VLAN's. VLAN's are used for separating network devices and traffic. For example, a company can implement VLAN's for admin and guest networks.

Organised Cybercriminals Threat Model

Organised cybercriminals are the 3rd least common and 3rd most dangerous threat actors. Organised cybercriminals are threat actors who work in groups to commit cybercrimes. These crimes can include identity fraud, Money laundering and selling services to other attackers. Organised cybercriminals are motivated by high ROI from targets. ROI stands for return on investment which means in basic terms how much money an attacker gains from a breach. Organised cybercriminals mainly use 4 attack vectors. These are spear-phishing, ransomware deployment, credential stuffing and exploiting known unpatched vulnerabilities. Spear-phishing is the most dangerous type of phishing as it is personalised towards a person specifically. The information used in a spear-phishing attack is usually found on social media or people searching sites. Ransomware deployment is the main vector used by cybercriminals. This is because ransomware encrypts your data and demands a ransom price to get your data back. This provides a quick and high ROI for cybercriminals. Credential stuffing is where attacker use compromised credentials to breach multiple accounts. This is because some users may use the same credentials for multiple accounts out of convenience. This may also lead to high ROI as an attacker can gain access to personal data and credit card information. Exploiting known vulnerabilities is where an attacker uses a known but unpatched vulnerability within a system to gain unauthorized access. For example, a vulnerability within an outdated Linux operating system. Organised cybercriminals target companies who have cyber insurance. Cyber insurance is financial cover for companies that have suffered from attack or breach. Cybercriminals also may target high risk individuals with high value digital assets or high ROI. There are 4 main protections

The first protection is robust account security. This means using multiple layers of defence to protect your accounts. I would recommend implementing 12–16-character passwords unique for each account which are generated and stored in a password manager. You should also implement MFA through authentication app or hardware key as a second layer to protect your account. Avoid SMS-based and email-based authentication as cybercriminals may use vectors like SMS swapping or compromise your email to gain access. For the final layer, you can store your recovery codes encrypted and in multiple locations. You may use cloud storage, physical drives or devices with 7-zip encryption or encrypted containers. This protects heavily against credential stuffing and reduces the ROI that a cybercriminal gains. The second protection is Anti-virus software with ransomware protection. You could use anti-virus software such as Windows Defender with controlled folder access or Bitdefender total security. These may sometimes alert with false positives as no system is perfect. This protects heavily against ransomware and reduces the main way for cybercriminals to gain ROI. The third protection is patch management by using automatic updates and testing your system for vulnerabilities. This means your systems gain the latest security patches and updates. It also means that you may discover vulnerabilities before an attacker does. This protects against a cybercriminal exploiting known vulnerabilities.

The fourth protection is OPSEC. OPSEC stands for operational security. This means you will be controlling and limiting the information that is publicly available. For example, reducing personal information on social media or opting out of people searching sites. This can include not posting content showing your location, public areas you go to or where you go for school/college. This heavily reduces the information that an attacker can use for a spear-phishing attack. Additional protections include encrypted backups and disabling services like RDP or SMB if you don't use them. more advanced protections include using secure protocols on home or company network, tighter OPSEC with fake names and email separation.

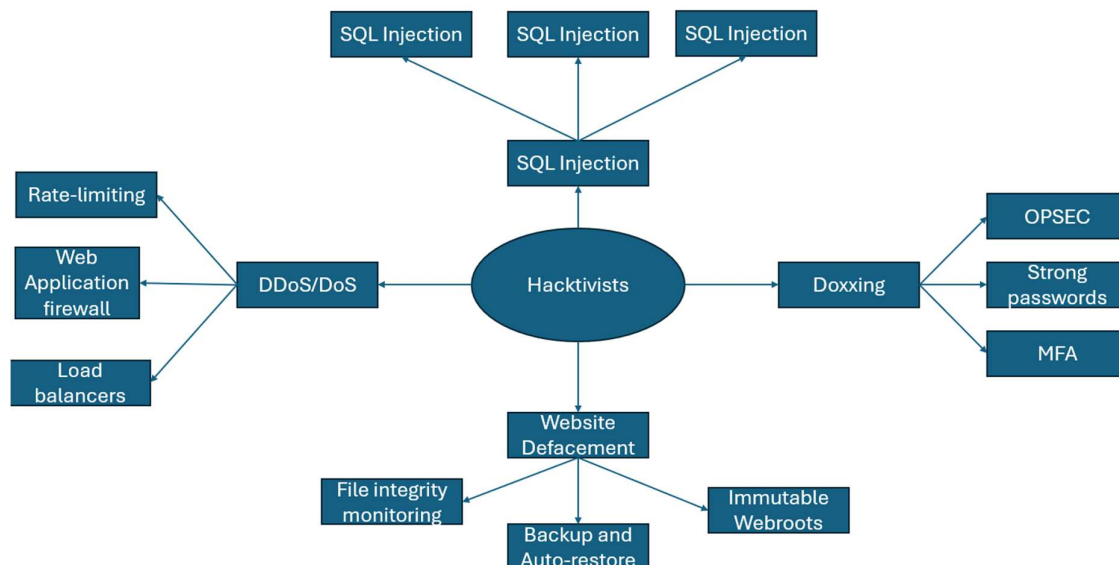


In the spider diagram, we can see the 4 most common attack vectors that organised cybercriminals use. We can also see the different types of protections for each attack vector. No additional or advanced protections are included in the spider diagram. You can find these protections in the paragraph above the diagram.

Hackivist Threat Model

Hacktivists are the 2nd least common and 2nd most dangerous threat actors in the world currently. Hacktivists are threat actors that work together in groups or alone to send a political message to the world, large-scale companies and governments. They are motivated by political gain from targets that may go against the beliefs they abide by especially from governments. Hacktivists commonly use attack vectors such as DDoS/DoS, Website defacement, Doxxing, data leaks/theft. DDoS stands for Distributed Denial of service attack while DoS stands for just Denial of service attacks. This is an attack where an attacker uses botnet or floods servers with requests to crash it. This can lead to disruption to business operations and system failures within critical infrastructure. Website defacement is where an attacker changes the pages of the website to a political message or image. This is commonly seen on large-scale company or government websites. Doxxing is where an attacker leaks or steals the personal information of a specific user. This information can include home address, full name, credit card information and DOB otherwise known as date of birth. Data leaks and theft are where an attacker gains unauthorized access to customer or company data and leaks it online. This is usually done through anonymous forums or on the dark web. Hacktivists specifically target Governments or cooperations who oppose their views. This can include Oil, surveillance and racist companies. To defend against hacktivists companies, users and governments need have DDOS Protection, SQL protection, Doxxing protection, Data theft prevention and website security. For DDOS protection, the first layer should be load balancers. This is because it allows for control over amount of load that web servers can handle. The second layer should be web application firewalls that blacklist Botnet IPs. This is because it prevents hacktivists from using infected devices to flood the servers with requests. The third layer is rate-limiting with requests. This means that the server limits the total number of requests that can happen within a duration. This heavily reduces the effectiveness of DDoS and DoS as an attacker cannot flood a sever easily. Secondly, for SQL protection, the first layer implemented should be input validation. This means that the user input is validated preventing them from using SQL commands. The second layer should be input sanitation. This is checking and cleaning user input from any malicious or harmful commands. This prevents an attacker from using SQL injection commands directly on website login pages. The third layer is specified parameters. These are placeholders for queries to hold values that are provided at runtime. This means it treats user input as data instead executable code reinforcing protections against SQL injection. Third, for Doxxing protection, the first layer should be OPSEC. This means limiting information on social media, email separation, fake names and opting out of people searching sites. This raises the cost that an attacker must pay to find information about their target. The second layer is strong and unique passwords for each account. This means that an attacker cannot use credential stuffing or brute force to compromise your accounts to gain personal information. The third layer is MFA. MFA should use hardware keys for the most sensitive accounts and authentication apps where hardware key isn't used. This forces an attacker to bypass multiple security steps and raises the cost further.

Fourth, for Data theft prevention, the first layer is device tracking. This means tracking your device if it were to be stolen. This allows for targets to locate, lock or even remotely wipe devices in the case of device theft. This prevents data theft as an attacker either is located, must spend resources on bypassing protections or loses data theft opportunity if the device were to be wiped. The second layer is device encryption. This should be full-disk encryption either via VeraCrypt or BitLocker. This means that the device is fully encrypted and can't be accessed without the correct decryption key. This raises the cost heavily for hackers as they must bypass the encryption either through a zero-day or physical coercion. The third layer is data encryption. This means that data should be encrypted at rest and during transit. This can be done through the usage of encrypted containers, 7-zip encryption and VPNs. This further raises the cost as an attacker cannot interception or access the data easily without high risk of detection or burning a zero-day. Fifth, for web security, the first layer is FIM otherwise known as File Integrity Monitoring. This automatically checks the website's files for unauthorised changes which alerts administrators if core files are modified. This protects against website defacement as it allows security teams to rapidly detect, respond and restore against the defacement. The second layer is Immutable/ Read-only Webroot. This means setting up the web directory to read-only for the web server process. Therefore, any defacement attempt fails because the server can't write to its own files as updates require a separate and controlled deployment process. The third layer is backup and auto-restore. This means maintaining clean, encrypted and versioned backups of the entire website. Therefore, in a defacement the website can automatically restore known-good files within minutes of detecting unauthorised changes. This reduces downtime and lowers the visibility of the political message.



The spider diagram above shows the 4 most common attack vectors that hackers currently use. Data theft isn't included in this diagram as all other threat actors use Data Theft as a vector. There is more information on protections in the paragraph above the diagram.

Nation-state/APT Threat Model

This section is for high values targets, global-scale companies and potentially other governments. Do not use this section unless you are certain that Nation-state/APT is your threat model. Nation-state actors are the least common but most dangerous threat actors in the world. Nation-state actors are threat actors that are backed by a state to target high value assets or data. They are currently motivated by intelligence gathering, Political gains, Military gain and financial gain. Nation-state actors use attack vectors such as zero-day exploits, Spear-phishing with custom lures, Supply chain compromise and Watering hole attacks. Zero-day exploits are unknown vulnerabilities in software that can be used to bypass security protections and authentication. These are extremely rare and can only be used once before a patch is applied. Spear-phishing with custom lures is a type of phishing specifically personalised and designed to lure a specific target. This can be used to gain credentials or install custom malware on the target's devices. Supply chain compromise is where nation-state actors exploit third-party software that the target uses. For example, this may mean pushing a malicious security update or package that the target may not notice. Watering hole attacks are where nation-state actors compromise websites that the target uses to gain information or install malware on the target's device. For example, they may compromise a cloud storage provider to compromise their target. Nation-state actors usually target high value companies such as Google or Apple, Other governments or high values targets such as Journalists or whistleblowers.

Those with nation-state actors as their threat model must focus on reduction of zero-day exploits, Spear phishing prevention and reduction, Reduction and prevention of supply chain compromise and Watering hole prevention and reduction. First, for the reduction of zero-day exploits, the first layer is Patch management. Patch management is locating and patching vulnerabilities within systems. This is often supported by Pen testing to locate vulnerabilities that may have been missed and to test current security protections. Patch management reduces zero-day exploits as companies or users may be able to locate vulnerabilities in their own system before nation-state actors are able to. The second layer is VLAN's. VLAN's allow for separated network traffic and devices. This protects against nation-state as they must compromise multiple VLAN's or devices throughout the usage of zero-days which is expensive and reduces the ROI. The third layer is extreme separation of identity. This means using multiple different isolated accounts and operating systems on devices. This means that nation-state actors must use multiple zero-days for different operating systems or service providers. This raises the cost further and reduces the ROI heavily.

Second, for spear-phishing prevention and detection, the first layer is tight OPSEC. This can be done through limiting information publicly available such as on social media. This could mean using encrypted communication apps such as Signal or custom encrypted and anonymous channels. Therefore, this means less information for nation-state actors to craft spear-phishing with custom lures. This further raises the cost and reduces the ROI as nation-state must spend resources on finding information about you. The second layer is digital footprint reduction. This means reducing your digital footprint which can be easily traceable by nation-state actors if enough information is available. The footprint can be reduced through tools such as Tor or virtual machines. This is because Tor is a browser specifically made for anonymity and reduces your footprint as much as digitally possible. Virtual machines allow you to perform high-risk activities in an isolated environment that doesn't affect your host machine if something were to happen. This layer further reduces the information that nation-state actors can use for spear-phishing attacks. The third layer is Robust account security. This means protecting your accounts with the max protections. This can be done through using security decision frameworks, AI-driven detection (For companies mainly), RBAC, strong, unique passwords and MFA. These controls provide both technical and behavioural detection and prevention for phishing techniques that nation-state actors may use. This raises the cost significantly as nation-state actors are forced to use multiple zero-days and risk detection for an even more reduced ROI.

Third, for supply chain reduction and prevention, the first layer is software usage. This means controlling and deciding what software you will use. I would recommend using zero-knowledge providers such as Proton Drive or Sync.com for cloud storage. If you have the resources, you may also use self-hosted software such as a self-hosted Bitwarden. This layer raises the cost for nation-state as they cannot gain information from compromising or accessing third-party provider logs. This also reduces the effectiveness of spear-phishing attacks. The second layer is Controlled third-party access to systems. This can be done by limiting third-party permissions and access with RBAC. This means not depending on one provider for all activities. For example, you may use Sync.com for Cloud storage while using proton mail as your email provider. This layer raises the cost further as an attacker must compromise multiple systems at once and can't specifically target third-party provider to completely compromise the target. Finally, for the prevention and reduction of Watering hole attacks, the main layer is network-level protections. This means preventing a nation-state actor finding out what websites and third-party software that you use. This can be done through encrypted DNS with providers like Mullvad, Reputable or self-hosted VPN with no logs, no storage or record of history in browser and changing usage of websites for long durations to prevent behavioural tracking through patterns. This raises the cost as nation-state actors must bypass multiple layers to find the websites you use which may cost multiple zero-days and then compromise the third-party software. Additional and more advanced protections include Tails OS, air-gapped networks, VeraCrypt full disk encryption with hidden OS for plausibility deniability, cash instead of digital transactions, physical locks for devices and faraday bags.